

CÓMO CREAR UN PROGRAMA DE SEGURIDAD DE CONFIANZA CERO

Guía práctica de identidad, dispositivos, redes, aplicaciones, datos, cargas de trabajo, visibilidad, automatización y gobierno

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

La seguridad humana es lo primero. La confianza cero debe reducir el riesgo sin crear vigilancia innecesaria, discriminación ni barreras de accesibilidad.

1. Qué significa Confianza Cero

- Confianza Cero es un conjunto de principios y una estrategia de arquitectura empresarial, no un producto único.
- No otorgue confianza implícita por ubicación de red, propiedad del dispositivo, cargo o una autenticación anterior.
- Evalúe continuamente identidad, dispositivo, aplicación, datos, comportamiento y entorno.
- Proteja cada recurso mediante decisiones explícitas y privilegio mínimo.

2. Resultados empresariales y gobierno

- Relacione el programa con resiliencia, protección de datos, trabajo remoto, nube, cumplimiento y contención de incidentes.
- Cree patrocinio ejecutivo, un comité transversal, propietarios por pilar y un proceso de decisiones.
- Defina alcance, prioridades, financiación, dependencias, aceptación de riesgo, excepciones y resultados medibles.
- No trate Confianza Cero como un proyecto exclusivamente de red o identidad.

3. Arquitectura lógica de NIST

- El Motor de Políticas decide si el acceso se concede, se limita o se rechaza.
- El Administrador de Políticas establece o termina la conexión según la decisión.
- El Punto de Aplicación de Políticas habilita, monitorea y termina el acceso.
- Las decisiones deben utilizar identidad, dispositivo, recurso, amenazas, comportamiento y políticas organizacionales.

4. Descubrimiento del estado actual

- Inventarie usuarios, cuentas privilegiadas, cuentas de servicio, cargas, dispositivos, aplicaciones, datos, redes, API, SaaS, nube, OT/ICS y terceros.
- Mapee servicios empresariales críticos y dependencias.
- Identifique autenticación heredada, credenciales compartidas, dispositivos sin gestión, exposición pública, redes planas, privilegios excesivos y flujos sin monitoreo.
- Registre propiedad, ciclo de vida y retiro planificado.

5. Protección de identidades

- Use MFA resistente a phishing para acceso privilegiado y de alto riesgo cuando sea posible.
- Aplique acceso basado en riesgo y contexto.
- Use gestión de privilegios, elevación temporal, cuentas administrativas separadas y aprobación para roles sensibles.
- Administre identidades no humanas, secretos, certificados, API y cargas con la misma disciplina.
- Elimine cuentas inactivas y revise derechos periódicamente.

6. Dispositivos y puntos finales

- Exija inventario, propietario, sistema compatible, cifrado, configuración segura, protección y parches oportunos.
- Use salud y cumplimiento del dispositivo como señales de acceso.
- Separe políticas para dispositivos corporativos, personales, contratistas, compartidos, servidores, móviles y especializados.
- Ofrezca alternativas restringidas para quienes no puedan utilizar un dispositivo administrado estándar.
- Aísle o corrija dispositivos que se vuelvan riesgosos durante la sesión.

7. Redes y entornos

- Reduzca la dependencia de una red interna confiable.
- Segmente por servicio, sensibilidad, carga y riesgo.
- Use conexiones cifradas, proxies autenticados, controles de aplicación, protección DNS y salida controlada.
- Limite movimiento lateral y rutas administrativas.
- Proteja acceso remoto, sucursales, nube, centros de datos, OT/ICS y socios.

8. Aplicaciones y cargas de trabajo

- Inventarie aplicaciones, propietarios, autenticación, datos, integraciones, dependencias y despliegues.
- Proteja aplicaciones heredadas con gateways, proxies, segmentación o controles compensatorios.
- Use identidades de carga y credenciales de corta duración.
- Aplique desarrollo seguro, análisis de dependencias, firma, gestión de secretos, protección en ejecución y control de cambios.
- Autorice cada solicitud de API y servicio a servicio.

9. Protección de datos

- Descubra, clasifique, etiquete y asigne propietario a los datos sensibles.
- Aplique privilegio mínimo, cifrado, DLP, retención, eliminación y gestión de derechos.
- Use la sensibilidad del dato como señal de acceso.
- Monitoree descargas inusuales, acceso masivo, uso compartido externo y evasión.
- Evite datos de producción sin restricción en entornos inferiores.

10. Visibilidad, análisis y detección

- Centralice telemetría de identidad, endpoint, aplicación, nube, red, datos y administración.
- Normalice tiempo, identidad, dispositivo, recurso y sesión.
- Detecte viajes imposibles, abuso de tokens, privilegios anómalos, dispositivos riesgosos, movimiento lateral y acceso inusual a datos.

- Proteja registros y defina retención según riesgo y privacidad.
- Use incidentes para mejorar políticas.

11. Automatización y orquestación

- Automatice enriquecimiento, puntuación, contención, revocación, aislamiento y creación de casos.
- Exija aprobación humana para acciones con impacto empresarial, legal, de seguridad o disponibilidad.
- Pruebe por etapas e incluya reversión y apagado de emergencia.
- Evite que una falsa alerta se amplifique en toda la empresa.

12. Terceros y acceso remoto

- Use acceso por identidad y aplicación en lugar de acceso amplio a la red.
- Exija cuentas nominativas, MFA, dispositivos verificados, límites de tiempo, monitoreo y aprobación.
- Restrinja a los proveedores a sistemas y horarios necesarios.
- Elimine acceso al terminar el contrato o cambiar el rol.
- Incluya responsabilidades en contratos e incidentes.

13. OT, ICS, IoT y sistemas heredados

- Priorice seguridad física y disponibilidad.
- Use descubrimiento pasivo cuando el escaneo activo pueda interrumpir operaciones.
- Segmenta zonas y conductos, restrinja acceso remoto, monitoree protocolos y proteja estaciones de ingeniería.
- Use hosts de salto, gateways unidireccionales, listas permitidas y ventanas de mantenimiento.
- No imponga controles modernos en sistemas incompatibles sin revisión de ingeniería.

14. Nube y multinube

- Aplique principios consistentes de identidad, cargas, dispositivos, datos, registros y políticas.
- Use controles nativos manteniendo gobierno y evidencia comunes.
- Elimine exposición pública, roles excesivos, claves sin gestión y relaciones amplias de confianza.
- Proteja planos de administración y CI/CD.
- Evalúe continuamente desviación y rutas de ataque.

15. Diseño de políticas y decisiones

- Defina sujeto, recurso, acción, condiciones, riesgo, decisión, aplicación, duración y reautenticación.
- Use denegación predeterminada para recursos sensibles sin bloquear operaciones esenciales o de emergencia.
- Evalúe continuamente y reduzca privilegios cuando cambie el contexto.
- Registre razones de denegación y ofrezca soporte accesible y apelación.

16. Privacidad, ética y accesibilidad

- Recopile solo señales necesarias y defina retención y acceso.
- Revise monitoreo laboral con áreas legales, privacidad, trabajo y ética.
- Pruebe impacto sobre trabajadores remotos, contratistas, viajeros, personas con discapacidad y lugares con baja conectividad.
- Ofrezca avisos transparentes y métodos alternativos de autenticación y recuperación.
- No trate una puntuación de comportamiento como prueba automática de conducta indebida.

17. Estrategia de migración

- Comience con un servicio de alto valor o grupo definido.
- Cree dependencias, arquitectura objetivo, hitos, responsables, financiación, pruebas, reversión y retiro.
- Ejecute controles anteriores y nuevos en paralelo cuando sea necesario.
- Elimine rutas antiguas después de validar.
- Comunique y capacite antes de aplicar.

18. Pruebas y aseguramiento

- Pruebe autenticación, autorización, postura del dispositivo, segmentación, políticas, registros, revocación, recuperación y acceso de emergencia.
- Realice ejercicios y pruebas adversarias autorizadas.
- Pruebe tokens robados, dispositivos comprometidos, cuentas inactivas, privilegios excesivos, movimiento lateral y exfiltración.
- Verifique fallas seguras sin interrupción empresarial inaceptable.
- Repita pruebas después de cambios importantes.

19. Métricas e informes ejecutivos

- Mida cobertura de recursos, MFA resistente a phishing, dispositivos administrados, duración de privilegios, segmentación, cuentas obsoletas, excepciones, tiempo de revocación, contención y exposición de datos.
- Informe reducción de riesgo, no solo despliegue de herramientas.
- Muestre tendencias, dependencias, acciones vencidas, riesgos aceptados y decisiones.
- Evite métricas que premien bloquear trabajo legítimo.

20. Plan de 30, 60 y 90 días

- Días 1 a 30: gobierno, inventario de servicios críticos, supuestos de confianza, identidades privilegiadas y registros esenciales.
- Días 31 a 60: acceso condicional, señales de dispositivo, identidades de carga, segmentación prioritaria, clasificación de datos y restricciones a terceros.

- Días 61 a 90: automatización selectiva, pruebas de escenarios, retiro de rutas obsoletas, métricas y siguiente fase.

21. Evaluación de madurez

Pilar	Tradicional	Inicial	Avanzado	Óptimo
Identidad	Contraseñas y roles amplios	MFA para usuarios prioritarios	Acceso por riesgo y PAM	Resistente a phishing, continuo y automatizado
Dispositivos	Inventario limitado	Gestión básica	Acceso por cumplimiento	Postura continua y respuesta automática
Redes	Red plana confiable	Segmentación prioritaria	Segmentación por aplicación	Acceso dinámico de privilegio mínimo
Aplicaciones	Confianza heredada	SSO e inventario	Identidades de carga y política API	Autorización continua y protección en ejecución
Datos	Protección por ubicación	Pilotos de clasificación	DLP y derechos	La política acompaña al dato y al riesgo
Visibilidad	Registros aislados	Recopilación central	Análisis entre pilares	Retroalimentación y respuesta automática

22. Lista de preparación

- ☐ Patrocinador ejecutivo y propietarios por pilar
- ☐ Servicios y recursos críticos inventariados
- ☐ Arquitectura y hoja de ruta aprobadas
- ☐ MFA resistente a phishing priorizada
- ☐ Acceso privilegiado controlado
- ☐ Identidades no humanas gobernadas
- ☐ Postura del dispositivo usada en acceso
- ☐ Segmentación prioritaria implementada
- ☐ Acceso a aplicaciones y API aplicado
- ☐ Datos sensibles clasificados y protegidos
- ☐ Acceso de terceros restringido

- ☐ Telemetría y detecciones centralizadas
- ☐ Automatización probada con reversión
- ☐ Privacidad y accesibilidad revisadas
- ☐ Ejercicios de incidentes y emergencia completados
- ☐ Métricas y excepciones programadas

23. Referencias oficiales

- NIST SP 800-207 Zero Trust Architecture: <https://csrc.nist.gov/pubs/sp/800/207/final>
- NIST SP 1800-35 Implementing a Zero Trust Architecture: <https://csrc.nist.gov/pubs/sp/1800/35/final>
- NIST SP 800-207A Cloud-Native Access Control: <https://csrc.nist.gov/pubs/sp/800/207/a/final>
- CISA Zero Trust Maturity Model Version 2.0: <https://www.cisa.gov/resources-tools/resources/zero-trust-maturity-model>
- U.S. Department of Defense Zero Trust Strategy:
<https://dodcio.defense.gov/Portals/0/Documents/Library/DoD-ZTStrategy.pdf>
- Microsoft Zero Trust Guidance Center: <https://learn.microsoft.com/security/zero-trust/>

Licencia

Copyright © 2026 Alberto (Al) Leiva. Distribuido bajo la licencia CC BY-NC-SA 4.0.